

# GLV New-Client Onboarding Checklist

---

**Version:** 1.0 | **Created:** 2026-05-17 **Scope:** Every new client build, regardless of stack (WordPress, React SPA, or other) **Rule:** All 5 hardening items are DEFAULT scope. Never present as add-ons or up-charges.

---

## Phase 0 — Kickoff (Day 1)

---

- [ ] Create client directory: `orgs/glv/clients/<slug>/`
  - [ ] Create `context.json` from `pipeline-template.json` (fill: business\_name, domain, owner, stack, hosting, GitHub repo, Supabase project if applicable)
  - [ ] Create `pipeline.json` from template
  - [ ] Add client to GOALS.md summary
  - [ ] Confirm hosting account (SiteGround, Cloudflare, etc.) is under GLV control
  - [ ] Confirm GitHub repo created under `glvcrypto/<client-slug>` (private)
  - [ ] Confirm domain registrar access or transfer timeline
- 

## Phase 1 — Build Complete (before staging launch)

---

### Code & Deploy

- [ ] Git repo initialized with `main` branch protected (require PR review)
- [ ] Branch protection: no direct push to main
- [ ] GitHub Actions CI configured (build + lint at minimum)
- [ ] `.env` / secrets: all credentials in GitHub Secrets or SiteGround env vars — none hardcoded in source
- [ ] Secret scanning enabled on repo (Settings → Security → Secret scanning)
- [ ] Dependabot alerts enabled (Settings → Security → Dependabot)

### Stack-specific

#### WordPress builds:

- [ ] Theme in `glvcrypto/<client-slug>` repo, custom PHP (no page builder unless scoped)
- [ ] `WP_DEBUG` = false in production wp-config.php
- [ ] `DISALLOW_FILE_EDIT` = true in production wp-config.php
- [ ] `FORCE_SSL_ADMIN` = true in production wp-config.php

- [ ] WooCommerce (if applicable): HPOS enabled, no legacy meta queries

### React SPA builds (Lovable / custom):

- [ ] No `service_role` Supabase key in frontend source (run: `grep -r "service_role" src/`)
  - [ ] Supabase anon key is the only key exposed to browser
  - [ ] All Supabase tables have RLS enabled before launch
  - [ ] `npm audit` clean (0 high/critical vulnerabilities)
- 

## Phase 2 — Hardening (complete before or at launch) ☐

---

### Layer 1: Error Tracking & Logs

- [ ] Sentry project created (Free tier — sentry.io)
- [ ] Sentry DSN added to environment variables (not hardcoded)
- [ ] **WordPress:** `sentry/sentry-sdk` via Composer; PHP error handler in wp-config.php; JS SDK enqueued in functions.php
- [ ] **React SPA:** `@sentry/react` installed; `Sentry.init()` in main.tsx; `<ErrorBoundary>` wrapping app root; source maps uploaded in CI
- [ ] Sentry alert configured: email `amglvdigital@pm.me` on first new issue class
- [ ] Sentry alert configured: Slack webhook → #internal-dev for severity > warning
- [ ] Verified: test error fires and appears in Sentry dashboard

### Layer 2: Rate Limiting

- [ ] **If Cloudflare zone exists:** WAF rules added:
  - POST rate limit (contact/lead forms): 3-5 req/min per IP → block 15-30min
  - Known scanner UA block (sqlmap, nikto, acunetix, masscan)
  - Geo Managed Challenge for non-CA/US (optional, per client profile)
  - Bot Fight Mode: enabled
- [ ] **If no Cloudflare yet (WordPress):**
  - `Limit Login Attempts Reloaded` plugin installed and configured (4 attempts → 20min lockout → 24h after 2 lockouts)
  - Schedule Cloudflare Free tier addition post-launch
- [ ] **React SPA with Supabase:** Client-side submit rate limit wrapper in Supabase lib
- [ ] Verified: manual test of rate limit triggers expected block

### Layer 3: Uptime Monitoring

- [ ] UptimeRobot account: use existing GLV account (uptimerobot.com)
- [ ] Monitor added: `https://<domain>` — HTTP(S), 5-min interval

- [ ] Monitor added (if Supabase): `https://<project-ref>.supabase.co/rest/v1/` — HTTP(S), 5-min (keepalive + uptime)
- [ ] Alert contact: email `amglvdigital@pm.me`
- [ ] Alert contact: Slack webhook → #internal-dev
- [ ] Alert contact: Telegram webhook → boss agent (for after-hours)
- [ ] Alert threshold: 2 consecutive failures (10 min down) before notify
- [ ] Verified: tested by temporarily blocking domain in hosts file

## Layer 4: Security Hardening

### All stacks:

- [ ] SiteGround account 2FA enabled (covers all sites on the account — do once)
- [ ] Cloudflare account 2FA enabled (covers all zones — do once)
- [ ] GitHub repo: branch protection + secret scanning + Dependabot (see Phase 1)
- [ ] All admin accounts (GLV + client owner) have unique strong passwords (1Password or equivalent)

### WordPress builds (additional):

- [ ] `WP 2FA` plugin installed; TOTP enforced for all admin-role accounts
- [ ] 2FA backup codes documented and stored securely (not in repo)
- [ ] `Limit Login Attempts Reloaded` plugin installed (see Layer 2)
- [ ] `Wordfence Security` (Free) installed:
- File Change Detection: enabled (weekly auto-scan)
- Malware scan: enabled on theme + active plugins
- Firewall mode: DISABLED if Cloudflare is proxying (avoid double-firewall)
- [ ] Plugin vulnerability review cadence documented: monthly check of WPScan DB for installed plugins
- [ ] `xmlrpc.php` disabled or blocked (Cloudflare WAF rule or `.htaccess` )

### React SPA + Supabase (additional):

- [ ] Full RLS audit completed: every table in `public` schema has RLS enabled
- [ ] Every policy reviewed: no `USING (true)` on write operations unless explicitly intended
- [ ] No `service_role` key in frontend code (re-verify at launch)
- [ ] Supabase email notifications enabled (Settings → Notifications)

## Layer 5: Rollback Runbook

- [ ] Rollback runbook written at `orgs/glv/clients/<slug>/rollback-runbook.md`
- [ ] Runbook covers: code rollback, pipeline failure, hosting issue, database restore (if applicable)

- [ ] Runbook tested: Scenario A (code rollback) executed on staging — verified it works
  - [ ] Runbook includes emergency contacts: SiteGround chat URL, Aiden contact
  - [ ] Runbook committed and accessible to Aiden and Ben
- 

## Phase 3 — Launch Verification

---

- [ ] All 5 hardening layers verified complete (checklist above = all checked)
  - [ ] DNS records confirmed: A/CNAME pointing to production, not staging
  - [ ] SSL certificate active (SiteGround auto-SSL or Cloudflare flexible)
  - [ ] GSC property added: `sc-domain:<domain>` (Aiden Google account)
  - [ ] GA4 property created and tracking code installed
  - [ ] Sitemap submitted to GSC
  - [ ] `robots.txt` reviewed: no accidental `Disallow: /`
  - [ ] UptimeRobot: staging monitor updated to production URL (or add new, keep staging)
  - [ ] Sentry: environment tag changed from `staging` to `production`
  - [ ] Client owner briefed: 2FA setup on their WP admin (if WordPress)
  - [ ] Client owner briefed: how to reach GLV if site goes down (Aiden contact)
- 

## Phase 4 — First 30 Days (post-launch)

---

- [ ] Week 1: Check Sentry for any post-launch errors (real users reveal edge cases)
  - [ ] Week 2: Review UptimeRobot uptime report (expect 100%)
  - [ ] Week 2: Check Cloudflare Analytics for unusual traffic patterns (bot spikes etc.)
  - [ ] Week 4: Run Wordfence scan (WordPress) or `npm audit` (React SPA)
  - [ ] Week 4: Check Supabase logs for any auth anomalies or slow queries (if Supabase in stack)
  - [ ] Month 1 check-in with client: confirm everything loading correctly on their end
- 

## Stack Reference Card

---

| Item           | WordPress                          | React SPA (no Supabase)               | React SPA + Supabase                          |
|----------------|------------------------------------|---------------------------------------|-----------------------------------------------|
| Error tracking | Sentry PHP SDK + JS SDK            | Sentry @sentry/react                  | Sentry @sentry/react + Supabase notifications |
| Rate limiting  | Limit Login Attempts + CF WAF      | CF WAF (POST rate limit)              | CF WAF + client-side submit limiter           |
| Uptime         | UptimeRobot (domain)               | UptimeRobot (domain)                  | UptimeRobot (domain + Supabase endpoint)      |
| Security       | WP 2FA + Wordfence + wp-config.php | SiteGround 2FA + GH settings          | SiteGround 2FA + GH settings + RLS audit      |
| Rollback       | git revert + SiteGround backup     | git revert + FTP re-upload + CF purge | git revert + FTP + CF purge + Supabase PITR   |

## Existing Clients — Retrofit Status

| Client           | Stack                | Layer 1  | Layer 2                    | Layer 3  | Layer 4       | Layer 5  |
|------------------|----------------------|----------|----------------------------|----------|---------------|----------|
| Reyco Marine     | WP + WC              | x needed | x needed                   | x needed | x needed      | x needed |
| Titan Tiny Homes | React SPA            | x needed | ⚠ CF zone exists, no rules | x needed | x needed      | x needed |
| Fusion Financial | React SPA + Supabase | x needed | ⚠ CF zone exists, no rules | x needed | x RLS unknown | x needed |

Full retrofit specs in each client's [proposed-hardening-2026-05-17.md](#) .

*This checklist is enforced by GLV Dev as a definition-of-done gate. Items cannot be marked "out of scope" — they can only be deferred with a documented date and owner.*